Key Vault – Task 2 Deliverable

AccessGuard Health

Mapping the Day 2 RBAC Model to Azure Key Vault Roles and Testing Least Privilege

Project Name	AccessGuard Health
Organization	Horizon Valley Medical Center (HVMC)
Project Phase	Azure Key Vault integration
Task	Key Vault Task 2 – Map the Day 2 RBAC model to Key Vault roles and test least privilege
Date	November 9–10, 2026
Document Version	1.1 (adds the Reader test results, Section 6)
Status	**Complete.** Groups, members, role assignments, Secrets User tests and Reader tests (option B) all passed. Access-restore re-check after the test is pending Azure caching (Section 6.4).
Prepared By	Sabitha S Karanavar

1. Purpose

The objective of Key Vault Task 2 is to map the Day 2 Role-Based Access Control (RBAC) model to Azure Key Vault roles and to prove, through testing, that each role can perform only the actions it needs (least privilege). Access to the vault is granted through security groups, consistent with the rest of the AccessGuard Health project, and every role is scoped to this one vault rather than to the whole subscription.

Success criterion: the Reader is denied (Forbidden) when reading a secret value, and the Secrets User can read a secret but cannot create or delete one.

2. Key Vault Environment

Setting	Value
Vault name	hvmc-accessguard-kv
Resource group	HVMC-KeyVault-RG
Location / pricing tier	East US / Standard
Subscription	Azure subscription 1 (Default Directory)
Permission model	Azure role-based access control (RBAC)
Soft-delete / purge protection	Enabled / Enabled
Tags	project: HVMC-AccessGuard, owner: IAM-Admin, purpose: learning-keyvault, data: dummy-only

The vault uses Azure RBAC as its permission model, so the role assignments in this task are enforced. A vault set to the older "Vault access policy" model would ignore them, which is why this was checked before assigning any role (Figure 2). The vault is tagged *data: dummy-only*, consistent with the project scope (no real patient or employee data).

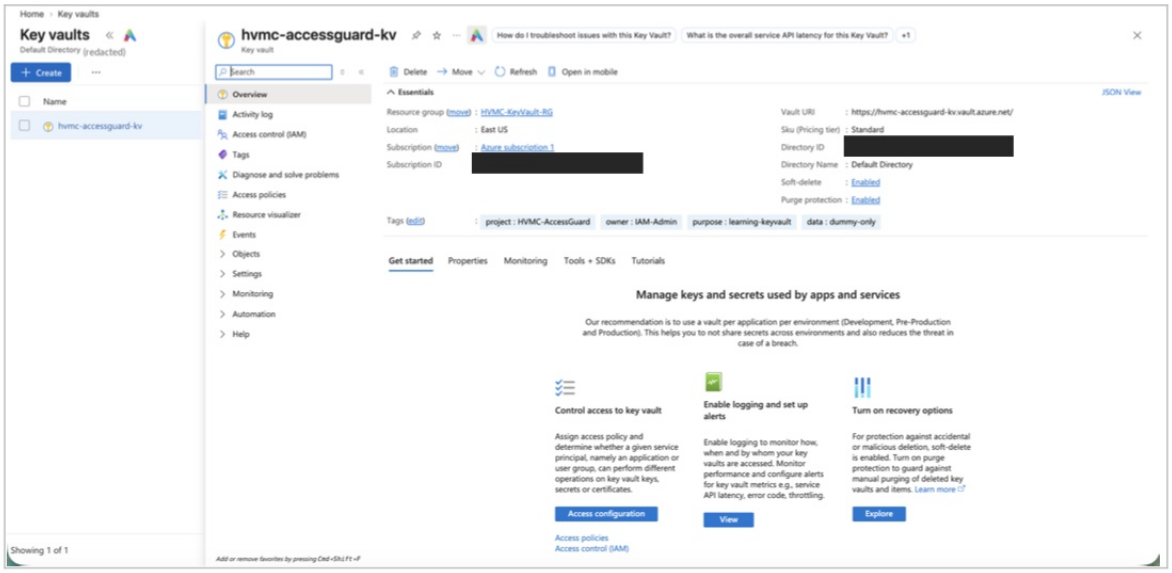


Figure 1 – Key vault overview: vault name, resource group, soft-delete and purge protection (tenant domain text masked).

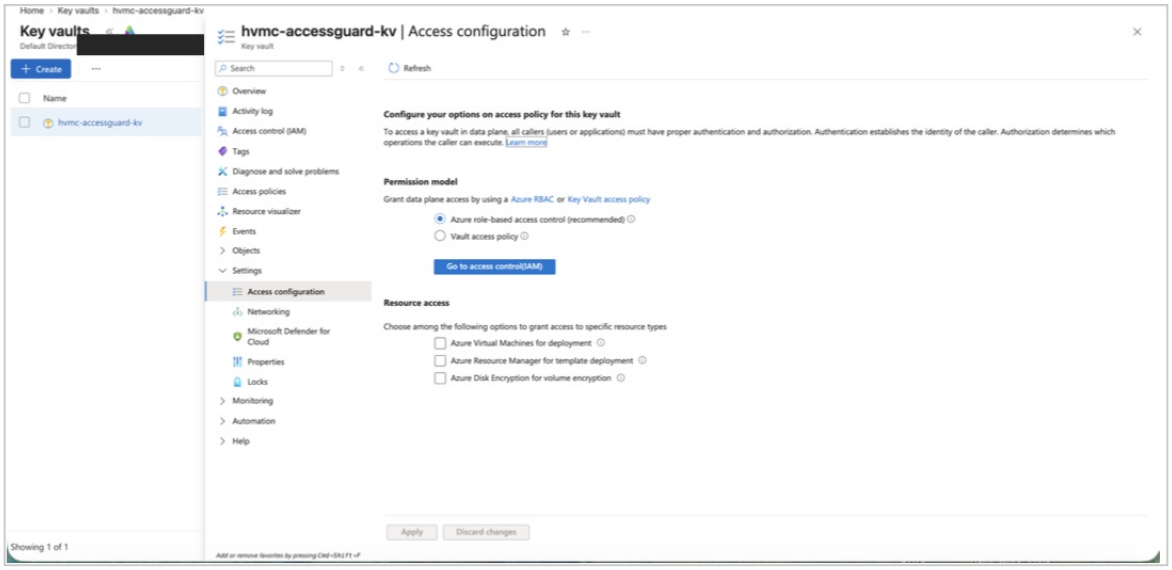


Figure 2 – Access configuration: permission model set to Azure role-based access control; Apply is greyed out, so nothing was changed.

3. RBAC Mapping Design

Three new security groups follow the Day 2 naming standard **SG-<Department>-<Application>-<Access>**. Each group maps to one built-in Key Vault role and has one member.

Group	Key Vault role	Member	Can	Cannot
SG-IT-KeyVault-Admin	Key Vault Administrator	Kevin O'Brien (IT Manager)	Manage the vault and its secrets	Act outside this vault (role is scoped to this vault only)
SG-Security-KeyVault-Read	Key Vault Reader	Denise Coleman (Security Supervisor)	See the vault and secret names (for audits)	Read secret values
SG-Services-KeyVault-SecretsUser	Key Vault Secrets User	HVMC Lab Results Sync (non-human identity)	Read a secret value (what an application needs)	Create or delete secrets

All three roles are assigned at the scope `/subscriptions/<subscription-id>/resourceGroups/HVMC-KeyVault-RG/providers/Microsoft.KeyVault/vaults/hvmc-accessguard-kv`.

4. Implementation

4.1 Create the security groups

In the Microsoft Entra admin center, three groups were created with **Group type = Security** and **Membership type = Assigned**, each with a description stating its purpose. The Entra role-assignable option was not needed for Key Vault roles.

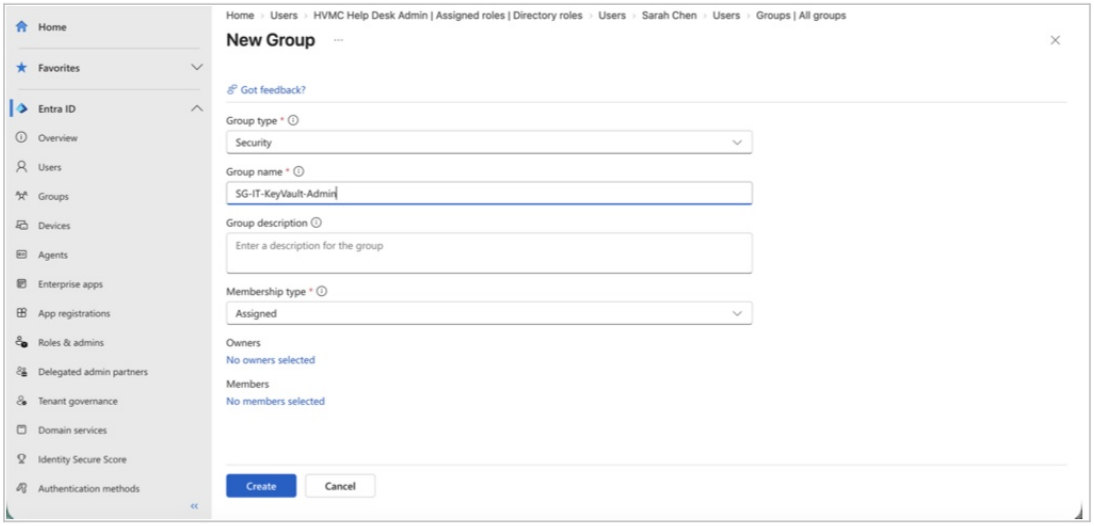


Figure 3 – New Group form for SG-IT-KeyVault-Admin (Security, Assigned).

Group	Object ID	Created (11/9/2026)
SG-IT-KeyVault-Admin	[redacted]	1:28 PM
SG-Security-KeyVault-Read	[redacted]	1:30 PM
SG-Services-KeyVault-SecretsUser	[redacted]	1:35 PM

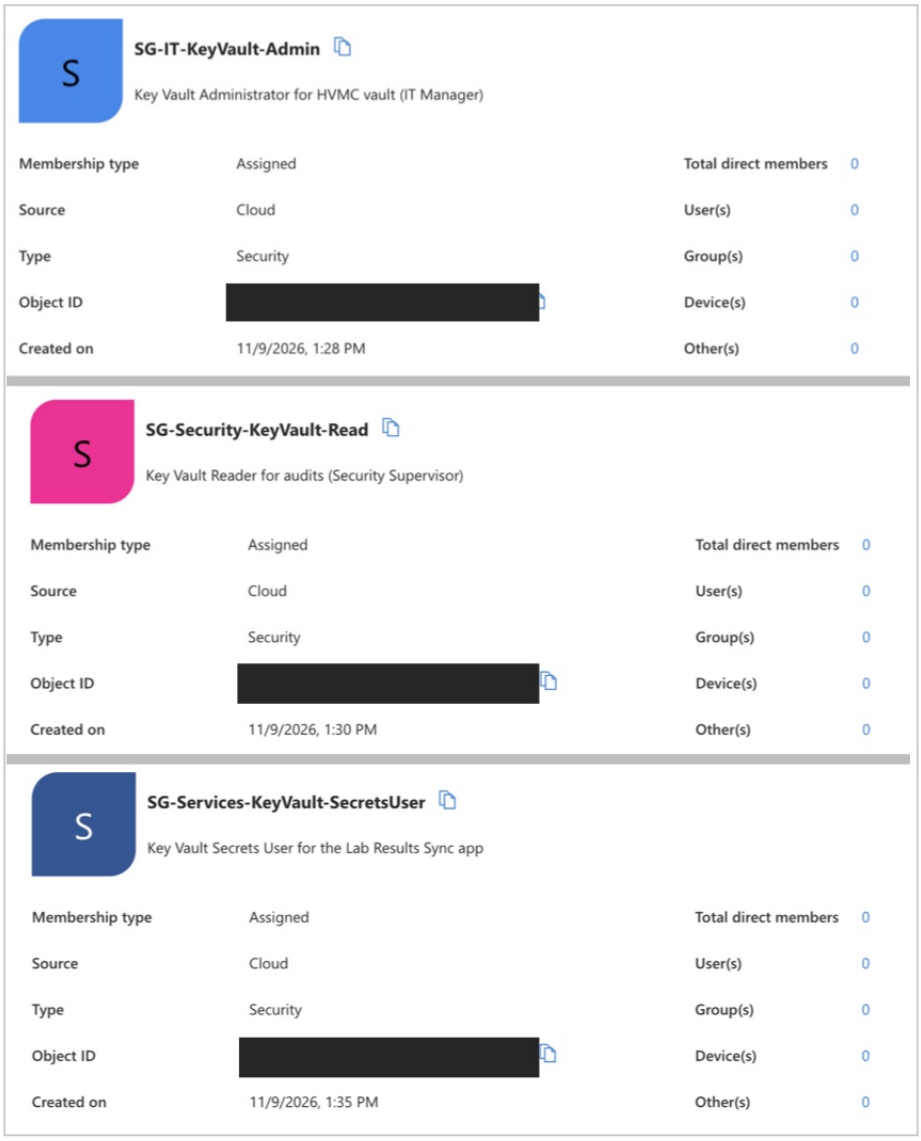


Figure 4 – The three groups after creation (Admin, Read, SecretsUser): type Security, membership Assigned, 0 members.

4.2 Add the human members

Kevin O'Brien (IT Manager) was added to SG-IT-KeyVault-Admin and Denise Coleman (Security Supervisor) to SG-Security-KeyVault-Read. Each group shows one direct member of type User.

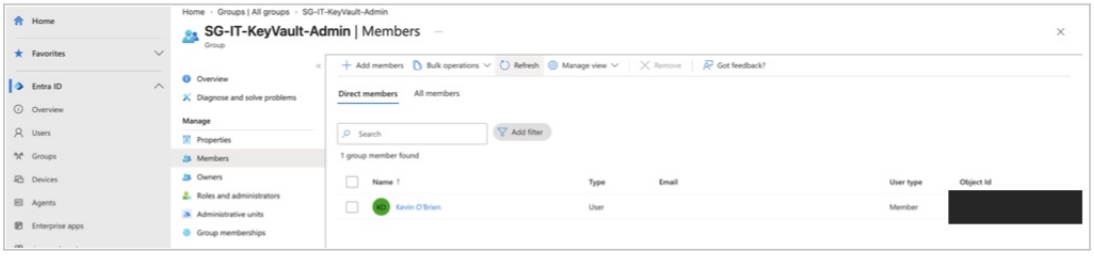


Figure 5 – SG-IT-KeyVault-Admin | Members: Kevin O'Brien (User).

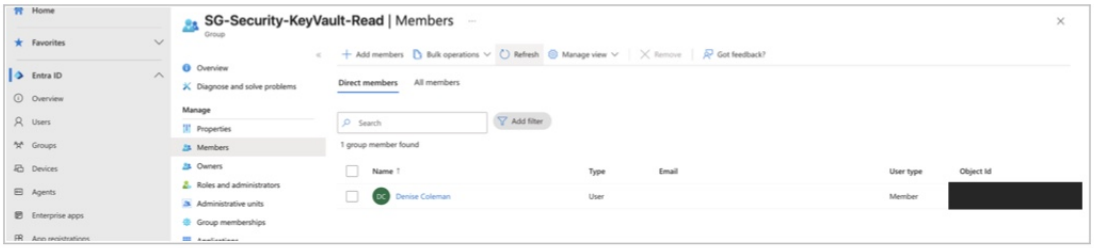


Figure 6 – SG-Security-KeyVault-Read | Members: Denise Coleman (User).

4.3 Add the non-human identity

The application **HVMC Lab Results Sync** is the project's non-human identity. It exists as an **app registration** (client ID [redacted], certificate credential status "Current") and as an **enterprise application / service principal** (object ID [redacted]). Only the service principal can be a group member, so it was added to SG-Services-KeyVault-SecretsUser through the *Add members* panel (Figures 7–9).

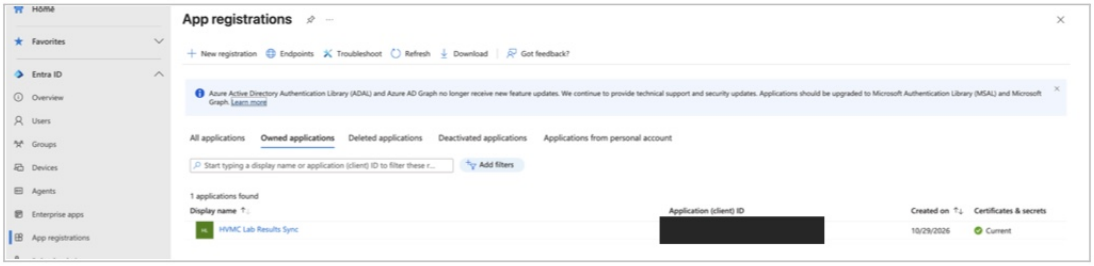


Figure 7 – App registrations: HVMC Lab Results Sync with a current certificate.

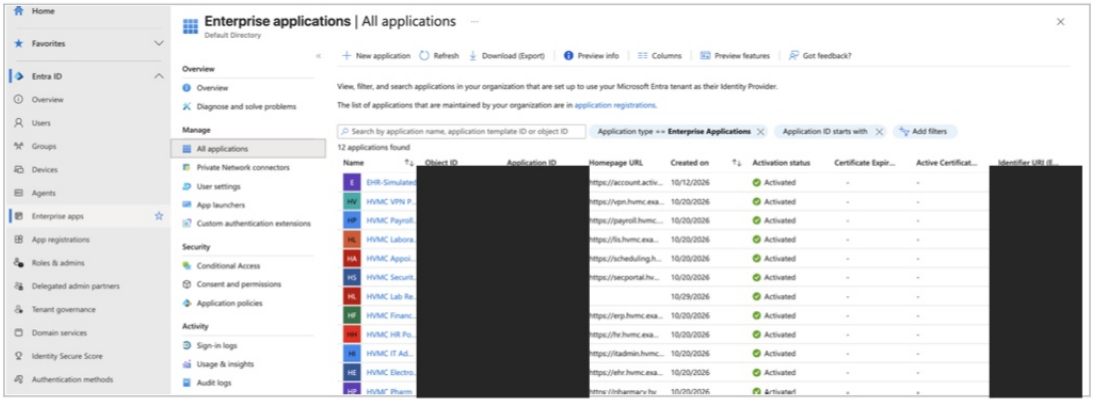


Figure 8 – Enterprise applications: the matching service principal (same application ID) is activated.

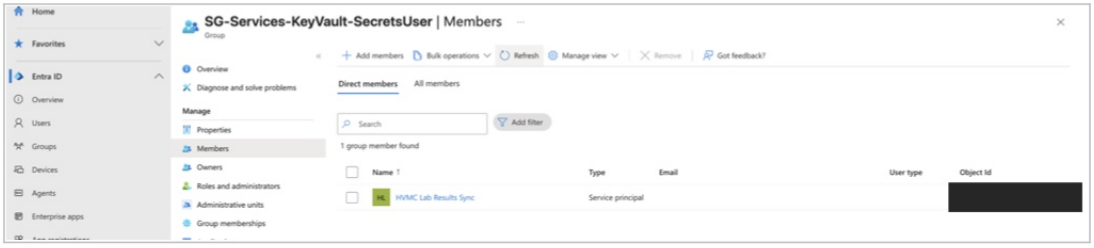


Figure 9 – SG-Services-KeyVault-SecretsUser | Members: HVMC Lab Results Sync, type Service principal.

4.4 Assign the Key Vault roles (vault scope only)

Roles were assigned from Azure Cloud Shell (Bash) with the Azure CLI. The script looks up each group's object ID by name and runs one role assignment per group, using the vault's resource ID as the scope so the roles cannot reach anything else in the subscription:

```
az role assignment create \
  --assignee-object-id <group-object-id> --assignee-principal-type Group \
  --role "<Key Vault role>" --scope <vault-resource-id>
```

The assignment list confirms all three roles on the three groups. The vault owner's own account also holds **Key Vault Secrets Officer** on the vault; it was already in place and is used only to administer the vault, never as a test subject.

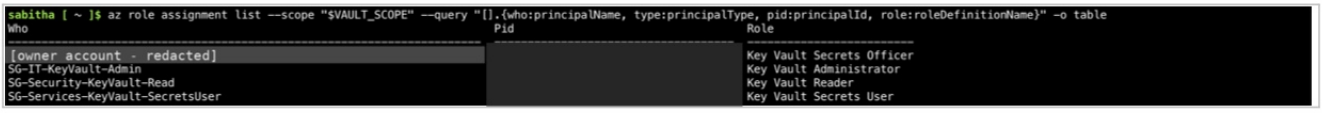


Figure 10 – Role assignments on hvmc-accessguard-kv (owner account email redacted).

Two secrets already existed in the vault (accessguard-api-key, servicenow-lab-password). A third, throwaway secret named **rbac-test-secret** (dummy value) was created with the owner account so that the read and delete tests never touch real secrets.



Figure 11 – Existing secret names listed, then the throwaway test secret created (no output means success).

5. Least-Privilege Test – Secrets User

The application signed in as itself with its certificate: no password and no MFA prompt. A separate Azure CLI configuration directory was used so the test session did not replace the administrator's own login. The first sign-in attempt passed the certificate with `-p` and was rejected (AADSTS7000215); current Azure CLI versions require `--certificate`, which worked (Section 7).

#	Action as the application	Expected	Actual result	Result
1	Sign in with its certificate	Succeeds	Signed in as client ID [redacted]	**PASS**
2	Read secret rbac-test-secret	Allowed	Secret value returned (dummy-test-value)	**PASS**
3	Create secret rbac-app-created	Denied	Forbidden, inner error ForbiddenByRbac, action secrets/setSecret/action	**PASS** (denied)
4	Delete secret rbac-test-secret	Denied	Forbidden, inner error ForbiddenByRbac, action secrets/delete	**PASS** (denied)

Both denials name the application as the caller and report the assignment as "not found" for that action, which shows the block comes from the role design. Because the delete was refused, rbac-test-secret is still in the vault.

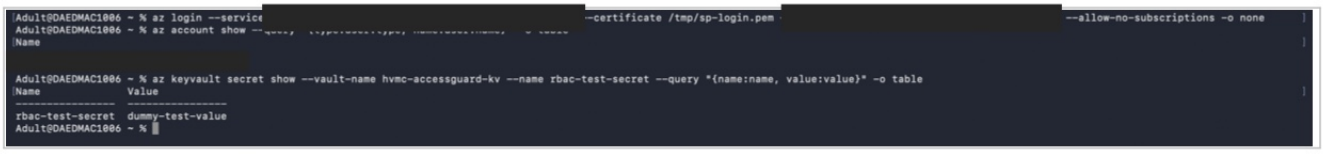


Figure 12 – Certificate sign-in as the application, then reading the test secret (allowed).

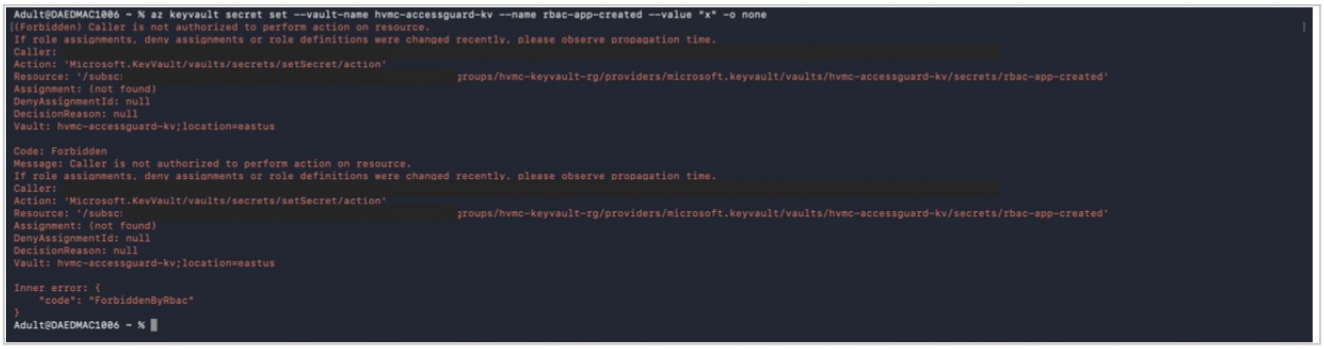


Figure 13 – Creating a secret as the application: Forbidden (ForbiddenByRbac).

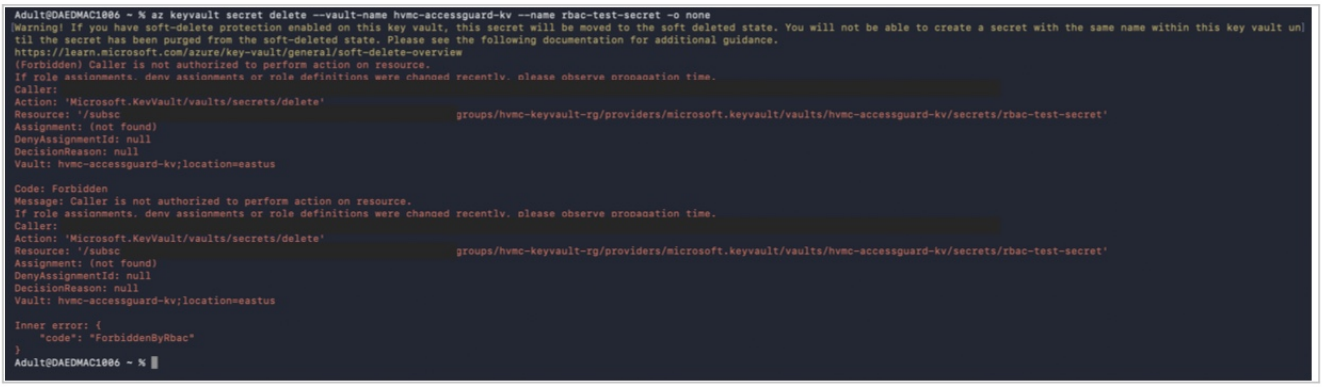


Figure 14 – Deleting a secret as the application: Forbidden (ForbiddenByRbac).

6. Least-Privilege Test – Reader (Option B)

Option B was used: the application **HVMC Lab Results Sync** temporarily took the Reader's place, because it signs in with its certificate (no password, no MFA prompt) and the test is quick to repeat. Roles add together, so the application had to be a member of **only** the Reader group during the test — otherwise its Secrets User role would still allow it to read secret values and the test would prove nothing. Option A (signing in as Denise Coleman) was not needed and remains optional.

6.1 Move the application to the Reader group

At 11:39 AM on 10 November the application was removed from SG-Services-KeyVault-SecretsUser and added to SG-Security-KeyVault-Read with the Azure CLI (`az ad group member remove / add`), run under the IAM administrator account. The change was verified from the application's side (its group memberships) and in the Entra admin center.

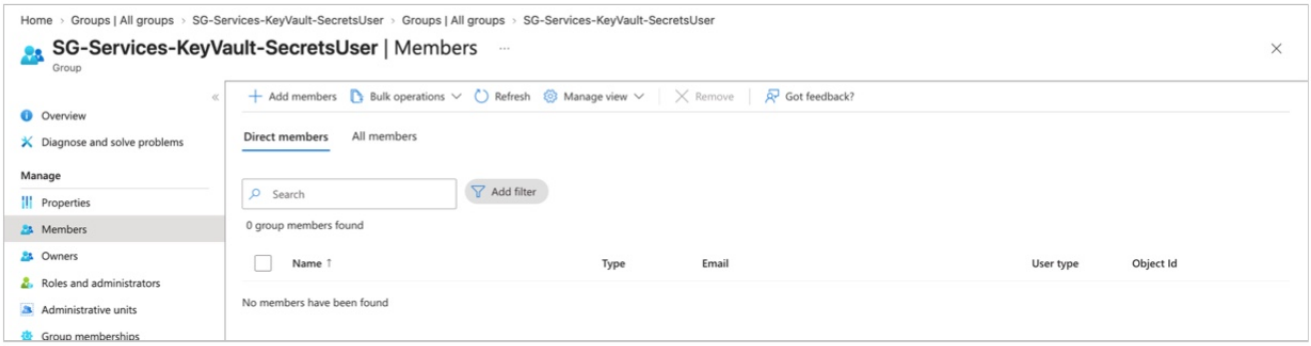


Figure 15 – SG-Services-KeyVault-SecretsUser | Members: 0 members. The application was removed for the Reader test.

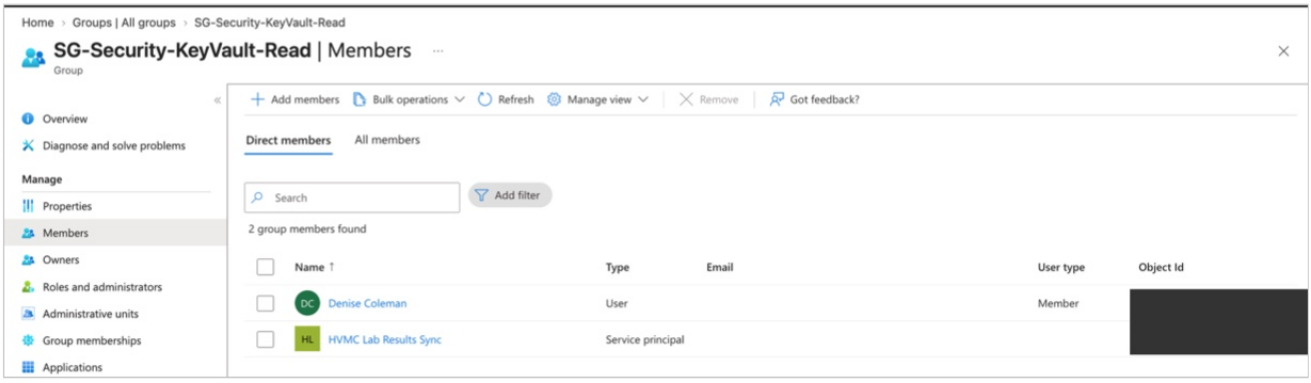


Figure 16 – SG-Security-KeyVault-Read | Members: Denise Coleman (User) and HVMC Lab Results Sync (Service principal).

6.2 Audit trail of the change

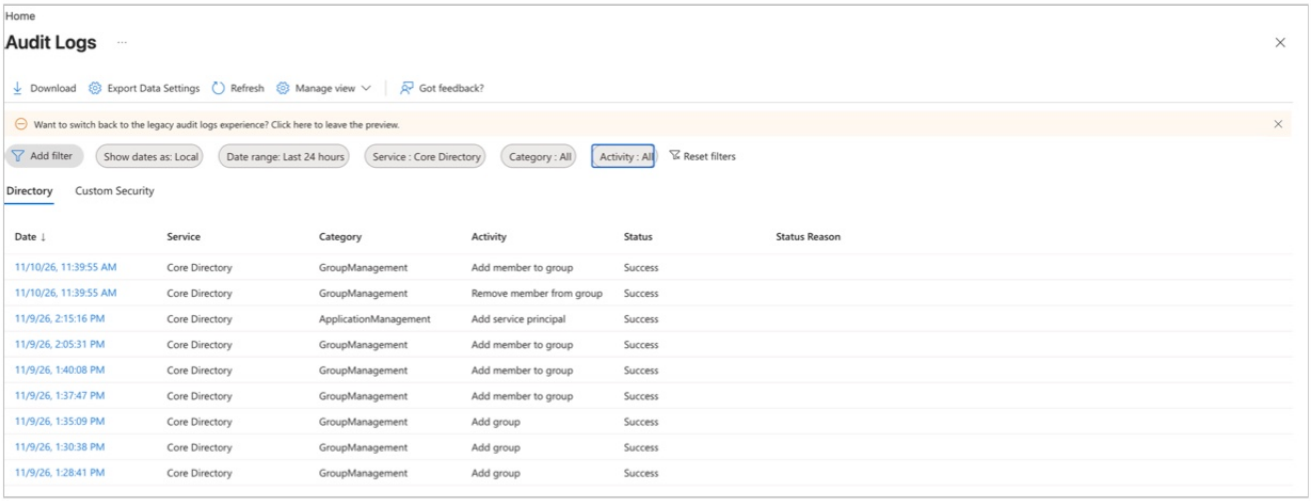


Figure 17 – Entra audit log (Core Directory): the groups and members created on 9 Nov, and the application moved from SecretsUser to Read at 11:39:55 AM on 10 Nov.

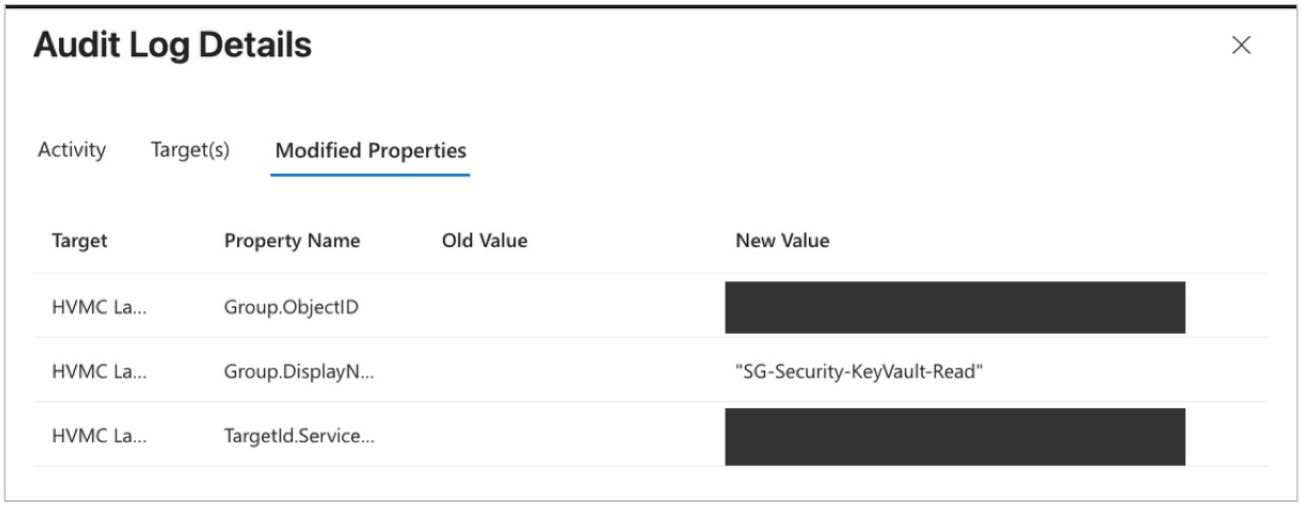


Figure 18 – Audit Log Details, Modified Properties: the application was added to Group.DisplayName "SG-Security-KeyVault-Read".



Figure 19 – Audit Log Details, Target(s): the service principal HVMC Lab Results Sync and the target group.

6.3 Reader tests

After waiting more than five minutes for the change to take effect, the application signed in with its certificate in a separate Azure CLI configuration directory (so the administrator's own login was not replaced) and ran three actions.

#	Action as the application (Reader)	Expected	Actual result	Result
R1	List secret names	Allowed	accessguard-api-key, rbac-test-secret, servicenow-lab-password listed	**PASS**
R2	Read the value of rbac-test-secret	Denied	Forbidden, inner error ForbiddenByRbac, action secrets/getSecret/action	**PASS (denied)**
R3	Create secret rbac-reader-created	Denied	Forbidden, inner error ForbiddenByRbac, action secrets/setSecret/action	**PASS (denied)**

> R1 and R2 together meet the success criterion: the Reader can see the vault's secret **names** (metadata, for audits) but is denied the secret **values**. Both denials report “Assignment: (not found)” for the action, so the block comes from the role design. Because R3 was refused, no secret named rbac-reader-created exists.

```
Adult@DAEDMAC1006 dae 6month_Sabi % export AZURE_CONFIG_DIR=~/.azure-kv-test
az login --service-principal -u "$CLIENT_ID" --certificate /tmp/sp-login.pem --tenant "$TE
NANT" --allow-no-subscriptions -o none
az account show --query "{type:user.type, name:user.name}" -o table
Name
------------------------------------

Adult@DAEDMAC1006 dae 6month_Sabi % az keyvault secret list --vault-name hvmc-accessguard-
kv --query "[].name" -o tsv
accessguard-api-key
rbac-test-secret
servicenow-lab-password
```

Figure 20 – Certificate sign-in as the application, then R1: the secret names are listed (allowed). The client ID shown as the account name is masked.

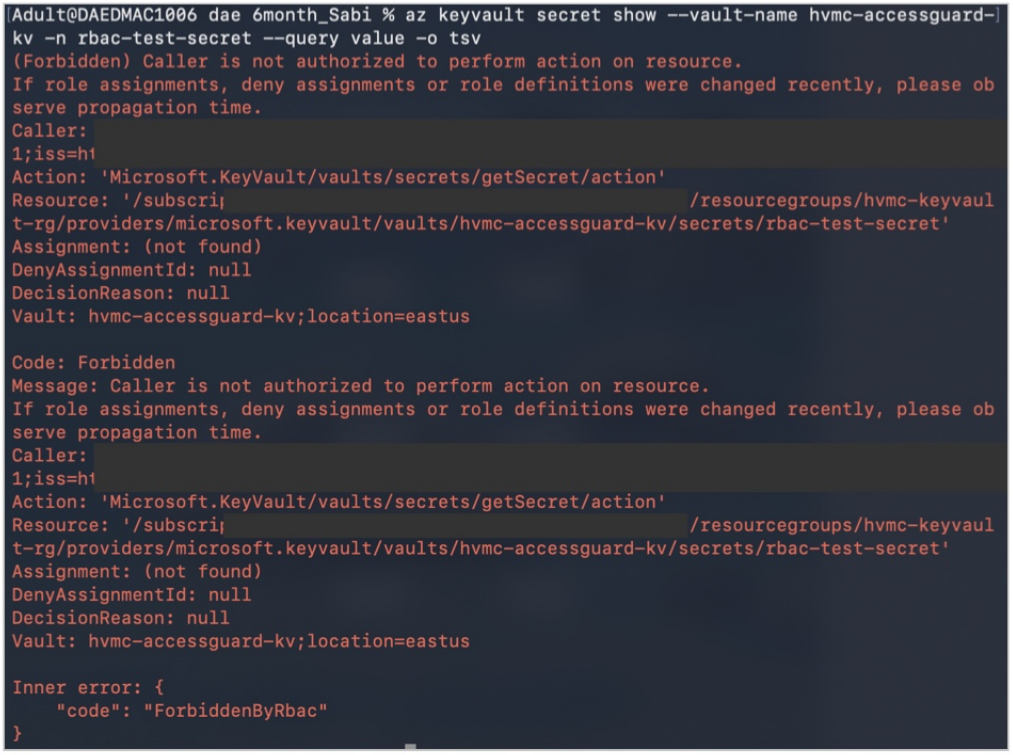


Figure 21 – R2: reading the value of rbac-test-secret as Reader is denied: Forbidden (ForbiddenByRbac), action secrets/getSecret/action.

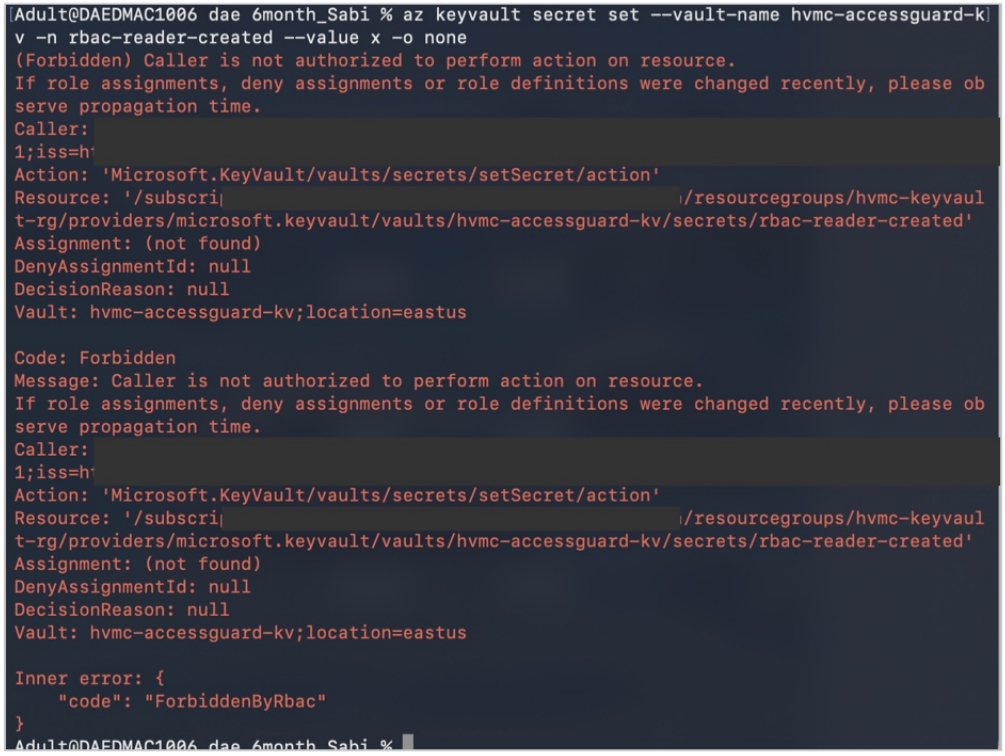


Figure 22 – R3: creating a secret as Reader is denied: Forbidden (ForbiddenByRbac), action secrets/setSecret/action.

6.4 Restore the design and clean up

At 12:23 PM the application was moved back: removed from SG-Security-KeyVault-Read and added to SG-Services-KeyVault-SecretsUser. The result was verified: the application's only group is SG-Services-KeyVault-SecretsUser, and that group still holds **Key Vault Secrets User** on the vault (role assignment list).

A re-check about 40 minutes later, signed in as the application, was **still Forbidden** (Figure 23), although the membership and role assignment were confirmed correct. Azure caches group memberships of service principals, and removing and re-adding a member can take a long time to take effect. The access-restore re-check will be repeated and recorded when the cache refreshes.

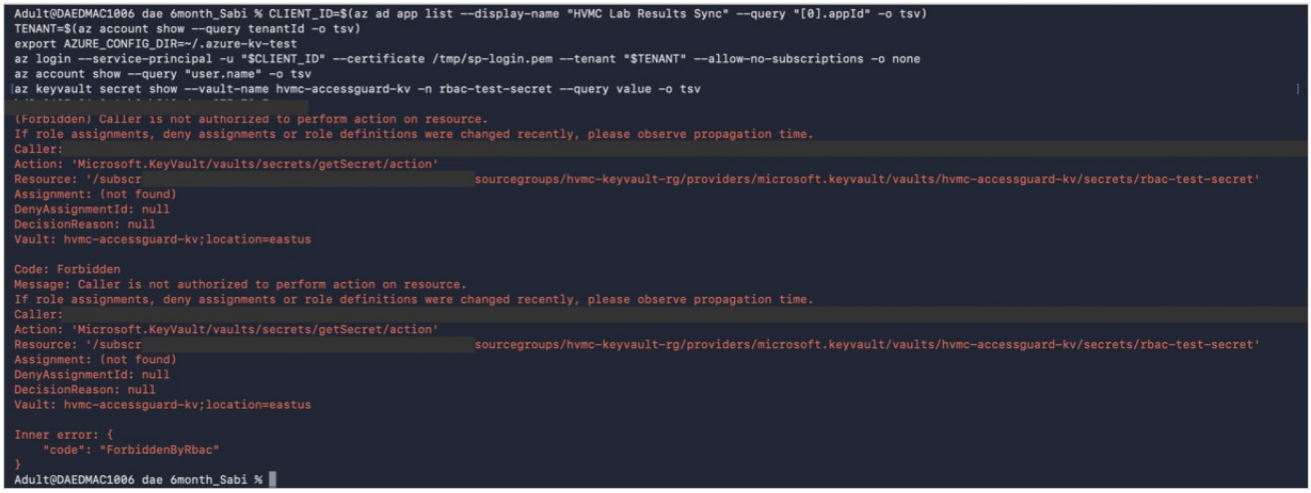


Figure 23 – Access-restore re-check (about 1:05 PM): signed in as the application, reading the secret is still Forbidden while Azure's group cache refreshes.

Cleanup: the temporary combined key-and-certificate file and the separate Azure CLI test profile were deleted from the workstation and verified as removed (1:17 PM).

7. Issues Encountered and Resolutions

Issue	Cause	Resolution
Application not found when adding it to the group	Search was typed into the Members-page filter, which only filters existing members.	Used the Add members panel; confirmed the service principal exists (Figures 7–9).
Role assignment output showed “role”: null	The create command's response left the role-name field empty.	Verified with az role assignment list; all three roles present (Figure 10).
Certificate sign-in rejected (AADSTS7000215)	Certificate passed with -p; newer Azure CLI no longer accepts that.	Used --certificate with a combined key and certificate file; sign-in succeeded.
Role list table hid the principal column	A column named “id” is hidden by the CLI table view.	Renamed the columns (who, pid, role) in the query.
The group's member list in the CLI looked empty	The Azure CLI member list does not show service principals.	Checked from the application's side (its group memberships) and in the audit log before changing anything.
“Insufficient privileges” when preparing the test	An old terminal tab was still signed in as the application, which may not read app registrations.	Used a new terminal tab with the administrator login. This also showed the application's own permissions are limited.
A test in a new tab returned the secret value	The new tab had no test profile set, so the Azure CLI used the administrator's login (Secrets Officer).	Always confirm who is signed in (`az account show`) before trusting a result; repeated the test as the application.
Access still Forbidden after moving the application back	Azure caches service-principal group memberships; changes can take a long time to apply.	Verified membership and role assignment are correct; re-check scheduled.

8. Security Considerations

- Access is granted to security groups, never directly to users (Day 2 governance policy).
- Least privilege: three roles, each limited to what that identity needs, all scoped to one vault.
- The application authenticates with a certificate rather than a password; its private key is never shown in this document.
- Destructive tests used a throwaway secret; soft-delete and purge protection are enabled on the vault.
- Every group change during the Reader test is recorded in the Entra audit log, and the original design was restored afterwards.
- The temporary key-and-certificate file and the separate Azure CLI test profile were deleted after the tests.

- Screenshots were cropped to remove account headers; tenant, subscription and object IDs, the account e-mail and IP address are masked.

9. Key Outcomes

- Three Key Vault security groups were created following the Day 2 naming standard and populated with one member each.
- The non-human identity HVMC Lab Results Sync was added to the Secrets User group as a service principal.
- Three Azure RBAC role assignments were made at vault scope and verified.
- Secrets User least privilege was proven: read allowed; create and delete denied with 403 Forbidden.
- **Reader least privilege was proven: secret names listed; reading a value and creating a secret denied with 403 Forbidden.**
- Next: the application reads its secret from the vault in a Python script, and vault audit logs go to Log Analytics (Task 3).

10. Deliverables

- Key Vault security group set (3 groups) with membership evidence
- Role assignment evidence at vault scope
- Secrets User least-privilege test results with screenshots
- Reader least-privilege test results with screenshots and audit-log evidence
- Key Vault Task 2 documentation for GitHub portfolio